

Buenas prácticas para la protección de datos

Breve descripción:

Este componente formativo orienta la aplicación práctica de buenas prácticas, controles y ejercicios organizacionales para proteger datos personales. Aborda el diagnóstico del tratamiento de información, la recolección responsable, la implementación de controles, la gestión de solicitudes e incidentes y la elaboración de planes de mejora para prevenir riesgos y sanciones.

Tabla de contenido

Introducción	4
1. Diagnóstico organizacional del tratamiento de datos personales	6
1.1. Identificación de bases de datos personales	6
1.2. Clasificación práctica de la información	10
1.3. Análisis inicial de cumplimiento	14
2. Controles para proteger la información personal.....	17
2.1. Controles administrativos.....	18
2.2. Controles técnicos	23
2.3. Controles físicos.....	28
3. Gestión de solicitudes, incidentes y riesgos	33
3.1. Atención de derechos de los titulares	33
3.2. Gestión de incidentes de seguridad	37
3.3. Análisis de riesgos legales.....	41
4. Ejercicios prácticos de aplicación organizacional	47
4.1. Caso práctico: empresa comercial.....	48
4.2. Caso práctico: institución educativa	52
4.3. Caso práctico: área de talento humano.....	56
5. Plan de mejora para la protección de datos personales.....	61

5.1. Elaboración del diagnóstico final	61
5.2. Diseño de acciones de mejora.....	65
5.3. Presentación del plan de protección de datos	70
Síntesis	75
Glosario	76
Referencias bibliográficas	77
Créditos	78

Introducción

La protección de datos personales constituye una responsabilidad fundamental para las organizaciones que recolectan, almacenan, utilizan, consultan, circulan, conservan o eliminan información de personas naturales. Su adecuada gestión requiere reconocer qué datos se tratan, con qué finalidad se utilizan, quiénes pueden acceder a ellos y qué medidas deben implementarse para reducir riesgos. Por esta razón, resulta necesario integrar prácticas que permitan fortalecer el cumplimiento, proteger los derechos de los titulares y prevenir situaciones relacionadas con el uso indebido o la divulgación no autorizada de información.

Este componente formativo aborda la protección de datos desde una perspectiva práctica y organizacional. Para ello, integra el diagnóstico del tratamiento de datos personales, la aplicación de controles administrativos, técnicos y físicos, la gestión de solicitudes e incidentes, el análisis de riesgos y el desarrollo de ejercicios relacionados con empresas comerciales, instituciones educativas y áreas de talento humano. Estos contenidos permiten relacionar las responsabilidades de la organización con situaciones que pueden presentarse durante el manejo cotidiano de la información personal.

Finalmente, se plantea la elaboración de un plan de mejora para la protección de datos personales, construido a partir de los hallazgos, riesgos, controles y evidencias identificados durante el proceso. Este plan permite definir acciones administrativas, técnicas y de capacitación, establecer responsables y plazos, conservar evidencias de cumplimiento y realizar seguimiento a las medidas implementadas. De esta manera, el componente promueve una gestión preventiva y de mejora continua orientada a

fortalecer la protección de la información y la atención adecuada de los derechos de los titulares.

1. Diagnóstico organizacional del tratamiento de datos personales

El diagnóstico organizacional del tratamiento de datos personales permite reconocer cómo una entidad recolecta, almacena, usa, consulta, comparte, conserva o elimina información asociada a personas naturales. Este proceso constituye el punto de partida para aplicar buenas prácticas, establecer controles y prevenir riesgos relacionados con el manejo inadecuado de la información.

En una organización, los datos personales pueden encontrarse en documentos físicos, formularios digitales, hojas de cálculo, bases de datos, plataformas tecnológicas, correos electrónicos, contratos, registros académicos, historias laborales, encuestas, listados de asistencia o archivos compartidos. Por esta razón, el diagnóstico comprende no solo los documentos, sino también los procesos, responsables, finalidades, autorizaciones, accesos y evidencias asociados al tratamiento.

Realizar un diagnóstico básico permite determinar si los datos tratados son necesarios, cuentan con una finalidad clara, disponen de la autorización correspondiente y se encuentran protegidos mediante medidas adecuadas. A partir del conocimiento del estado real de sus bases de datos, la organización puede tomar decisiones para corregir errores, disminuir riesgos y fortalecer la confianza de clientes, trabajadores, proveedores y demás titulares de la información.

1.1. Identificación de bases de datos personales

La identificación de bases de datos personales consiste en reconocer los conjuntos organizados de información que contienen datos de personas naturales. Estas bases pueden encontrarse en medios físicos o digitales y pertenecer a diferentes

áreas, como talento humano, comercial, administrativa, financiera, académica, jurídica, atención al cliente o sistemas.

Una base de datos personal no depende únicamente de una plataforma tecnológica. También puede estar conformada por carpetas físicas, formularios impresos, archivos de Excel, listados de asistencia, hojas de vida, contratos, encuestas, fotografías, registros de proveedores o comunicaciones almacenadas en correos electrónicos. Para identificar una base de datos personal, es pertinente formular las siguientes preguntas:

- ¿Qué datos personales se recolectan?
- ¿En qué área o proceso se recolectan?
- ¿Para qué se utiliza la información?
- ¿Quién tiene acceso a los datos?
- ¿Dónde se almacenan?
- ¿Existe autorización del titular?
- ¿Durante cuánto tiempo se conserva la información?
- ¿Qué riesgos pueden presentarse durante el tratamiento?

Estas preguntas permiten establecer un panorama inicial sobre la ubicación, finalidad, acceso, conservación y condiciones de tratamiento de los datos personales.

Bases de datos de clientes, empleados y proveedores

Las bases de datos de clientes, empleados y proveedores son comunes en la mayoría de las organizaciones. Cada una contiene información diferente y requiere controles acordes con su finalidad y nivel de riesgo. Para diferenciarlas, se deben considerar sus principales características:

- **Bases de datos de clientes.** Pueden incluir nombres, números de identificación, teléfonos, correos electrónicos, direcciones, historial de compras, solicitudes, reclamos o información relacionada con servicios contratados. Su uso debe limitarse a las finalidades autorizadas, como atención comercial, facturación, prestación del servicio o comunicaciones previamente aceptadas.
- **Bases de datos de empleados.** Suelen contener hojas de vida, contratos, afiliaciones, datos bancarios, incapacidades, información familiar, certificaciones y registros laborales. Por el tipo de información que contienen, requieren mayor reserva, control de acceso y confidencialidad.
- **Bases de datos de proveedores.** Pueden incluir datos de contacto, identificación, información tributaria, contratos, certificaciones, soportes de pago y datos bancarios. Aunque suelen relacionarse con personas jurídicas, también pueden contener datos personales de representantes legales, contactos comerciales o proveedores naturales.

Reconocer el tipo de base de datos permite establecer controles de tratamiento y protección acordes con la información que contiene.

Datos recolectados en formularios físicos y digitales

Los formularios físicos y digitales son medios frecuentes para recolectar datos personales. Se utilizan en inscripciones, solicitudes de información, encuestas, compras, procesos de selección, matrículas, eventos, trámites administrativos o atención de clientes.

Un formulario adecuado debe solicitar únicamente los datos necesarios para cumplir una finalidad específica. Pedir información excesiva o sin relación con el trámite aumenta el riesgo de incumplimiento y afecta la confianza del titular. Todo formulario debe informar, de manera clara:

- Quién recolecta la información.
- Para qué se recolectan los datos.
- Qué tratamiento recibirá la información.
- Cuáles son los derechos del titular.
- Dónde se consulta la política de tratamiento de datos.
- Qué canales existen para consultas o reclamos.

En formularios físicos, la autorización puede evidenciarse mediante firma o aceptación escrita. En formularios digitales, puede conservarse mediante casillas de aceptación, registros de fecha y hora, trazabilidad del formulario o confirmaciones electrónicas. De esta manera, la organización conserva evidencia del proceso de recolección y de la autorización correspondiente.

Reconocimiento de finalidades del tratamiento

La finalidad del tratamiento corresponde al propósito para el cual se recolectan y utilizan los datos personales. Reconocerla es fundamental, debido a que la información no debe utilizarse para actividades diferentes de aquellas informadas al titular. Las finalidades pueden variar según el área o proceso organizacional:

- **Talento humano.** La información puede utilizarse para gestionar contratos, nómina, seguridad social y bienestar laboral, de acuerdo con las necesidades propias de la relación laboral.

- **Área comercial.** Los datos pueden destinarse a la atención de clientes, gestión de ventas, trámite de garantías o envío de comunicaciones previamente autorizadas.
- **Área administrativa.** El tratamiento puede relacionarse con procesos de facturación, pagos, archivo documental o gestión de proveedores.

En todos los casos, la finalidad debe ser clara, específica y comprensible. Deben evitarse expresiones generales como «para cualquier actividad de la organización», porque el titular debe conocer con precisión el uso que se dará a sus datos.

1.2. Clasificación práctica de la información

La clasificación práctica de la información permite organizar los datos personales según su naturaleza, nivel de protección y riesgo. Esta clasificación contribuye a definir quién puede acceder a la información, cómo debe almacenarse, qué controles deben aplicarse y qué precauciones se requieren durante su uso.

No todos los datos personales tienen el mismo nivel de protección. Algunos pueden ser consultados con mayor facilidad; otros pertenecen al ámbito privado del titular, y algunos requieren protección reforzada porque pueden afectar su intimidad, dignidad o seguridad.

Datos públicos, privados y semiprivados

A continuación, se presenta un video que permitirá profundizar en la clasificación de los datos personales y comprender las características que determinan sus condiciones de acceso, uso y tratamiento.

Video 1. Datos públicos, privados y semiprivados



[Enlace de reproducción del video](#)

Transcripción del video. Datos públicos, privados y semiprivados

Los datos personales pueden clasificarse según sus características, el nivel de reserva que requieren y las condiciones de acceso. Esta clasificación permite comprender que no toda información tiene el mismo grado de protección.

En primer lugar, están los datos públicos. Corresponden a información que puede ser conocida por cualquier persona porque no está sometida a reserva. Puede consultarse en registros públicos, documentos oficiales u otras fuentes de acceso público. Sin embargo, esto no significa que pueda utilizarse indiscriminadamente.

Su tratamiento debe responder a una finalidad legítima y respetar los principios aplicables a la protección de datos personales.

Transcripción del video. Datos públicos, privados y semiprivados

En segundo lugar, están los datos privados, que pertenecen al ámbito personal del titular y requieren mayor nivel de reserva. Entre ellos se encuentran la dirección de residencia, teléfonos personales, correos electrónicos, información laboral y datos familiares.

Debido a su carácter privado, su acceso y utilización deben realizarse bajo condiciones que garanticen la protección de los derechos del titular.

Por otra parte, se encuentran los datos semiprivados. Estos no tienen un carácter estrictamente íntimo, pero tampoco son de libre acceso. Su conocimiento puede ser relevante para determinados sectores o actores, según la finalidad para la cual sean requeridos.

Un ejemplo representativo es la información financiera o crediticia, que puede utilizarse para evaluar situaciones relacionadas con decisiones comerciales, contractuales o de crédito.

En conclusión, distinguir entre datos públicos, privados y semiprivados permite identificar las condiciones para acceder, utilizar y tratar la información personal. Así, la protección debe ajustarse a la naturaleza de los datos y a la finalidad para la cual fueron recopilados.

Datos sensibles en procesos organizacionales

Los datos sensibles son aquellos que pueden afectar la intimidad del titular o generar discriminación si se utilizan de forma inadecuada. Por esta razón, su

tratamiento exige mayor cuidado y debe realizarse solo cuando exista una justificación clara.

En las organizaciones pueden encontrarse datos sensibles en certificados médicos, incapacidades, datos biométricos, restricciones laborales, información de salud, condiciones familiares, orientación psicológica o registros asociados a situaciones personales especiales. Cuando se identifiquen datos sensibles, deben aplicarse medidas reforzadas, entre ellas:

- Restringir el acceso únicamente al personal autorizado.
- Evitar su recolección cuando no sea necesaria.
- Conservarlos en medios seguros.
- Informar claramente la finalidad del tratamiento.
- Protegerlos contra pérdida, alteración o divulgación indebida.
- Eliminar la información cuando deje de ser necesaria.

Estas medidas contribuyen a reducir los riesgos derivados del tratamiento de información que requiere especial protección.

Datos de niños, niñas y adolescentes

Los datos de niños, niñas y adolescentes requieren protección especial. Su tratamiento debe respetar el interés superior del menor y garantizar sus derechos fundamentales.

Estos datos pueden encontrarse en instituciones educativas, deportivas, culturales, de salud, recreativas o de servicios sociales. Pueden incluir nombres, documentos, edad, información de acudientes, fotografías, videos, registros

académicos, datos de salud y autorizaciones de salida o de participación en actividades.

Para proteger esta información, se recomienda:

- Solicitar únicamente los datos necesarios.
- Contar con autorización del representante legal cuando corresponda.
- Evitar publicar fotografías o videos sin autorización.
- Restringir el acceso a información académica, médica o familiar.
- Proteger listados, matrículas y datos de contacto.
- Capacitar al personal que maneja información de menores.

La aplicación de estas medidas permite reforzar la protección requerida por las características particulares de estos titulares.

1.3. Análisis inicial de cumplimiento

El análisis inicial de cumplimiento permite determinar si la organización trata los datos personales de acuerdo con las finalidades, autorizaciones, derechos, deberes y controles establecidos. Este análisis contribuye a identificar debilidades y definir acciones de mejora.

El cumplimiento no depende únicamente de disponer de documentos escritos. También requiere que las políticas se apliquen, el personal conozca sus responsabilidades, los titulares puedan ejercer sus derechos y existan controles para prevenir accesos no autorizados, pérdida de información o uso indebido de los datos.

Verificación de autorizaciones

La verificación de autorizaciones consiste en determinar si la organización cuenta con evidencia de que el titular autorizó el tratamiento de sus datos personales. La

autorización debe estar relacionada con una finalidad clara y conservarse como soporte. Durante esta revisión, se deben considerar los siguientes aspectos:

- Existencia de autorización del titular.
- Finalidad informada.
- Identificación del responsable del tratamiento.
- Medio utilizado para obtener la autorización.
- Fecha de autorización.
- Evidencia física o digital.
- Relación entre los datos recolectados y la finalidad.
- Procedimiento para consultas, reclamos o revocatoria.

Una autorización incompleta o inexistente puede generar riesgos. Por ello, es importante revisar formatos, formularios, registros digitales y demás evidencias disponibles para determinar si respaldan adecuadamente el tratamiento realizado.

Revisión de políticas existentes

La política de tratamiento de datos personales informa a los titulares cómo se recolecta, usa, almacena, protege y gestiona su información. Esta política debe ser clara, actualizada y accesible. Durante su revisión, se debe determinar si incluye:

- Identificación del responsable.
- Finalidades del tratamiento.
- Derechos de los titulares.
- Procedimiento para consultas y reclamos.
- Canales de atención.
- Tratamiento de datos sensibles, cuando aplique.

- Medidas generales de seguridad.
- Fecha de actualización.

No basta con disponer de una política almacenada en un archivo interno. Esta debe estar disponible para consulta y guardar correspondencia con las prácticas reales de la organización.

Identificación de hallazgos básicos

Los hallazgos básicos son situaciones que evidencian debilidades, riesgos o posibles incumplimientos en el tratamiento de datos personales. Su identificación permite priorizar las acciones de mejora. Entre los hallazgos frecuentes se encuentran:

- Bases de datos sin responsable definido.
- Formularios sin autorización clara.
- Finalidades demasiado generales.
- Datos sensibles recolectados sin justificación.
- Acceso amplio a información reservada.
- Políticas desactualizadas.
- Falta de evidencias de autorización.
- Archivos físicos sin control.
- Bases de datos antiguas sin depuración.
- Uso de datos para campañas no autorizadas.

El diagnóstico debe finalizar con una relación básica entre el área, los datos tratados, el riesgo identificado y la acción recomendada. Esta relación permite convertir los hallazgos obtenidos durante el diagnóstico en insumos concretos para definir acciones de mejora y fortalecer la protección de los datos personales.

2. Controles para proteger la información personal

Los controles para proteger la información personal son medidas que permiten reducir riesgos durante la recolección, almacenamiento, uso, circulación, consulta, conservación y eliminación de datos personales. Estos controles contribuyen a prevenir accesos no autorizados, pérdida de información, uso indebido, divulgación no permitida, modificación incorrecta o conservación de datos sin justificación.

La protección de datos personales no depende de una sola acción. Requiere combinar controles administrativos, técnicos y físicos, de acuerdo con el tipo de información tratada, el nivel de riesgo, la finalidad del tratamiento y las áreas que intervienen en su manejo. Por ejemplo, una base de datos comercial requiere medidas diferentes de las aplicadas a una historia laboral, un registro médico, una hoja de vida o una base con información de menores de edad. Los tres tipos de controles cumplen funciones complementarias:

- **Controles administrativos.** Organizan la gestión interna mediante políticas, procedimientos, responsabilidades, capacitación y mecanismos de seguimiento. Permiten establecer reglas para que el personal conozca cómo debe actuar durante el tratamiento de datos personales.
- **Controles técnicos.** Protegen la información almacenada o tratada en sistemas, equipos, aplicaciones y servicios digitales. Incluyen medidas relacionadas con autenticación, copias de seguridad, cifrado y control de accesos.
- **Controles físicos.** Protegen documentos, equipos, soportes y espacios donde se conserva información personal. Su aplicación busca prevenir pérdidas,

sustracciones, consultas indebidas o exposición de información a personas no autorizadas.

La aplicación articulada de estos controles permite establecer quién accede a los datos, qué uso se les da, dónde se almacenan, cómo se conservan y qué acciones se adoptan cuando se presenta un incidente.

2.1. Controles administrativos

Los controles administrativos son medidas relacionadas con la organización interna, la asignación de responsabilidades, la definición de políticas, la documentación de procedimientos y la formación del personal. Su propósito es establecer reglas claras para el manejo adecuado de los datos personales. Estos controles permiten que las personas que intervienen en el tratamiento de información conozcan qué acciones pueden realizar, cuáles deben evitar, a quién deben reportar una novedad y qué procedimiento deben seguir ante una solicitud o incidente. Sin controles administrativos, la protección de datos puede quedar sujeta a decisiones improvisadas o criterios individuales. Los principales controles administrativos pueden organizarse de la siguiente manera:

- **Responsables de las bases de datos.** Cada base de datos debe contar con responsables definidos para su administración, custodia y actualización. Esta asignación facilita el seguimiento y evita que la información quede bajo responsabilidades imprecisas.
- **Políticas y procedimientos.** La organización debe establecer orientaciones para la recolección, uso, conservación y protección de los datos personales.

Los procedimientos permiten trasladar estas orientaciones a las actividades cotidianas de cada área.

- **Capacitación y confidencialidad.** El personal que maneja información personal debe conocer sus responsabilidades y las prácticas aplicables a sus funciones. Los acuerdos de confidencialidad complementan este control cuando, por las características del proceso, resultan necesarios.
- **Atención a titulares.** Deben existir canales definidos para recibir y gestionar consultas o reclamos relacionados con datos personales. Estos mecanismos permiten organizar la atención y asignar responsables para su trámite.
- **Inventario y conservación.** Mantener un inventario de las bases de datos permite identificar la información tratada y establecer tiempos de conservación. También facilita revisar periódicamente las autorizaciones y finalidades asociadas al tratamiento.

Estos controles proporcionan una estructura organizacional para gestionar la información personal de manera responsable.

Políticas internas de tratamiento

Las políticas internas de tratamiento son orientaciones que establecen cómo se deben recolectar, usar, almacenar, proteger y eliminar los datos personales dentro de la organización. Estas políticas deben ser claras, conocidas por el personal y coherentes con los procesos reales en los que se maneja información.

Una política interna no debe permanecer únicamente como un documento archivado. Debe servir como guía práctica para las áreas que recolectan datos, atienden solicitudes, administran bases de datos, gestionan contratos, realizan campañas o

conservan documentos físicos y digitales. Para facilitar su aplicación, los elementos principales de una política pueden organizarse así:

- **Datos y finalidades.** La política debe precisar qué datos personales trata la organización y cuáles son las finalidades asociadas con su recolección y uso. Esto permite relacionar la información solicitada con una necesidad concreta del proceso.
- **Responsables.** Debe establecer quiénes tienen responsabilidades relacionadas con el manejo de la información. Esta definición facilita la asignación de funciones y el seguimiento de las actividades de tratamiento.
- **Derechos y canales de atención.** Debe indicar los derechos de los titulares y los canales disponibles para presentar consultas o reclamos. Esta información facilita el ejercicio de los derechos relacionados con los datos personales.
- **Medidas de seguridad.** La política debe incluir las medidas generales aplicadas para proteger la información durante su almacenamiento, consulta, uso y conservación, de acuerdo con las condiciones de cada proceso.
- **Tratamientos especiales.** Cuando se manejen datos sensibles o información de menores de edad, la política debe establecer condiciones de protección acordes con las características de estos datos.
- **Gestión de incidentes.** Debe establecer las acciones que deben realizarse ante incidentes, accesos indebidos o usos no autorizados de la información, de manera que el personal conozca cómo proceder.

La política debe actualizarse cuando cambien los procesos, las finalidades, las bases de datos, los canales de atención o las formas de almacenamiento de la información.

Asignación de roles y responsabilidades

La asignación de roles y responsabilidades permite definir quiénes intervienen en el tratamiento de datos personales y cuáles son las funciones de cada área o persona. Esto evita confusiones y facilita el control del acceso, uso y conservación de la información.

En una organización pueden intervenir diferentes áreas. Por ejemplo, talento humano puede custodiar hojas de vida, contratos e incapacidades; el área comercial puede administrar datos de clientes; sistemas puede controlar accesos y respaldos; el área jurídica puede revisar autorizaciones y políticas; y atención al usuario puede recibir consultas o reclamos de los titulares. La distribución de responsabilidades puede estructurarse de acuerdo con las principales actividades del tratamiento:

- **Administración de bases de datos.** Requiere definir quién es responsable de cada base y quiénes están autorizados para consultar o gestionar su información. Esto permite relacionar el acceso con las funciones asignadas.
- **Conservación de autorizaciones.** Debe establecerse el área encargada de custodiar las evidencias físicas o digitales mediante las cuales se respalda la autorización del titular.
- **Atención de solicitudes.** Una persona o equipo debe asumir la gestión de las solicitudes presentadas por los titulares y conservar los soportes correspondientes a la atención realizada.
- **Reporte de incidentes.** Debe existir un responsable o canal definido para recibir y gestionar los reportes relacionados con pérdida, acceso indebido, divulgación u otras situaciones que comprometan información personal.

- **Actualización y depuración.** Es necesario establecer quiénes pueden actualizar, corregir o depurar las bases de datos, de manera que estas actividades se realicen bajo responsabilidades previamente asignadas.
- **Entrega de información a terceros.** El acceso o intercambio de datos con terceros debe quedar limitado al personal autorizado y responder a una necesidad relacionada con el tratamiento de la información.

Cuando los roles no están definidos, aumenta el riesgo de acceso indebido, duplicidad de información, pérdida de soportes, demoras en la atención de solicitudes o uso de datos para finalidades no autorizadas.

Acuerdos de confidencialidad

Los acuerdos de confidencialidad son compromisos mediante los cuales una persona reconoce su deber de proteger la información a la que tiene acceso durante el desarrollo de sus funciones. Estos acuerdos pueden aplicarse a trabajadores, contratistas, proveedores, practicantes o terceros que manejen datos personales.

La confidencialidad no implica únicamente abstenerse de divulgar información. También comprende evitar el uso indebido de los datos, no copiarlos sin autorización, no compartirlos mediante canales inseguros, no almacenarlos en dispositivos personales sin permiso y no consultarlos cuando no exista una necesidad relacionada con la función asignada. Los principales compromisos pueden organizarse de la siguiente manera:

- **Uso autorizado.** La información debe utilizarse exclusivamente para las finalidades relacionadas con las funciones o actividades autorizadas. El

acceso a los datos no habilita su utilización para propósitos personales o diferentes de los establecidos.

- **Reserva de la información.** Los datos no deben compartirse con personas no autorizadas. Este compromiso comprende tanto la comunicación directa como la entrega de documentos, archivos o accesos a terceros.
- **Protección de documentos y archivos.** La persona debe proteger los documentos físicos y digitales a los que tenga acceso y evitar prácticas que puedan facilitar su pérdida, copia o divulgación indebida.
- **Reporte de incidentes.** Las pérdidas, accesos indebidos o incidentes relacionados con información personal deben reportarse mediante los mecanismos definidos por la organización.
- **Finalización de la relación.** Cuando termine una relación laboral o contractual, la información debe devolverse o eliminarse según corresponda, manteniendo la reserva incluso después de finalizar las funciones.

Este tipo de control fortalece la responsabilidad individual y reduce los riesgos asociados con el manejo informal de datos personales.

2.2. Controles técnicos

Los controles técnicos son medidas apoyadas en herramientas, configuraciones, sistemas o recursos tecnológicos que permiten proteger la información personal en ambientes digitales. Su propósito es prevenir accesos no autorizados, pérdida de datos, alteraciones, filtraciones o usos indebidos de los sistemas en los que se almacena información.

Estos controles son especialmente importantes cuando los datos se encuentran en plataformas, computadores, correos electrónicos, aplicaciones, servidores, sistemas de información, hojas de cálculo compartidas, formularios web o servicios en la nube.

Los controles técnicos deben ajustarse al nivel de riesgo. Una base con datos de contacto puede requerir controles básicos, mientras que una base con información laboral, datos sensibles o datos de menores de edad requiere medidas más estrictas.

Contraseñas y autenticación

Las contraseñas constituyen una primera barrera para prevenir accesos no autorizados a sistemas, equipos o archivos que contienen datos personales. Sin embargo, una contraseña débil, compartida o repetida puede convertirse en un riesgo para la organización.

Una buena práctica consiste en utilizar contraseñas robustas, cambiarlas cuando sea necesario y evitar compartirlas mediante mensajes, correos electrónicos o documentos expuestos. También se recomienda asignar usuarios individuales, debido a que esta medida permite identificar quién accede a la información y qué acciones realiza. Las prácticas relacionadas con contraseñas y autenticación pueden organizarse así:

- **Contraseñas diferenciadas.** Utilizar contraseñas diferentes para cada sistema disminuye el riesgo de que el acceso comprometido a una herramienta facilite el ingreso a otros recursos de la organización.
- **Claves seguras.** Deben evitarse claves simples basadas en fechas, nombres o números consecutivos. Las contraseñas deben contribuir a reducir la posibilidad de accesos no autorizados.

- **Usuarios individuales.** Los usuarios y contraseñas no deben compartirse. La asignación individual permite relacionar los accesos y las acciones realizadas con una persona determinada.
- **Doble factor de autenticación.** Cuando sea posible, este mecanismo complementa la contraseña con una segunda forma de autenticación y fortalece el control de ingreso a los sistemas.
- **Gestión de accesos.** Las contraseñas deben cambiarse ante sospechas de acceso indebido y los permisos deben retirarse cuando una persona deje de participar en el proceso correspondiente.

La autenticación permite confirmar la identidad de quien ingresa a un sistema. Cuanto más sensible sea la información, mayor debe ser el nivel de control aplicado para acceder a ella.

Copias de seguridad y cifrado

Las copias de seguridad permiten recuperar información en caso de pérdida, daño, eliminación accidental, falla tecnológica o incidente de seguridad. Son necesarias para garantizar la continuidad de los procesos y evitar que la organización dependa de un único archivo o dispositivo.

Una copia de seguridad debe realizarse de forma periódica, almacenarse en un lugar seguro y someterse a pruebas de recuperación cuando sea necesario. No basta con crear respaldos si estos no pueden recuperarse o quedan disponibles para personas no autorizadas.

El cifrado es una medida técnica que protege la información al impedir que pueda ser interpretada fácilmente por personas no autorizadas. Puede aplicarse a

archivos, dispositivos, bases de datos, correos electrónicos o comunicaciones. Resulta especialmente útil cuando se manejan datos sensibles, información laboral, bases de clientes o documentos que requieren reserva. Las principales prácticas asociadas con estos controles son:

- **Periodicidad de los respaldos.** La organización debe definir con qué frecuencia realizará las copias de seguridad, teniendo en cuenta la información almacenada y la necesidad de recuperarla ante una pérdida o falla.
- **Almacenamiento seguro.** Las copias deben conservarse en ubicaciones protegidas y con acceso restringido. Guardar un respaldo sin controles puede generar nuevos riesgos para la información.
- **Pruebas de recuperación.** Los respaldos deben someterse a pruebas que permitan determinar si la información puede recuperarse cuando sea requerida. La existencia de una copia no garantiza por sí sola su utilidad.
- **Cifrado de información.** Los archivos con datos sensibles o información que requiere reserva pueden protegerse mediante cifrado para reducir el riesgo de interpretación por personas no autorizadas.
- **Gestión de respaldos obsoletos.** Las copias que ya no sean necesarias deben eliminarse de forma controlada. También debe evitarse su almacenamiento en dispositivos personales sin autorización.

Estas medidas permiten fortalecer la disponibilidad y confidencialidad de la información ante fallas, pérdidas o accesos no autorizados.

Control de accesos por perfiles

El control de accesos por perfiles consiste en permitir que cada persona consulte o modifique únicamente la información necesaria para cumplir sus funciones. Este control evita que todos los usuarios tengan acceso general a las bases de datos.

Por ejemplo, una persona del área comercial puede requerir datos de contacto de clientes, pero no debería acceder a incapacidades de trabajadores. El área de talento humano puede consultar información laboral, pero no necesariamente debe acceder a todas las bases comerciales. Asimismo, el área de sistemas puede administrar plataformas, pero sus accesos también deben estar controlados y justificados. Para aplicar este control, se deben considerar los siguientes componentes:

- **Perfiles según funciones.** Los permisos deben asignarse de acuerdo con las responsabilidades de cada persona. De esta manera, el acceso se relaciona directamente con las necesidades propias del cargo o proceso.
- **Permisos diferenciados.** Los perfiles pueden limitar las posibilidades de consulta, edición y descarga. No todas las personas que consultan información necesitan modificarla o conservar copias.
- **Revisión de accesos.** Los permisos deben revisarse periódicamente para retirar usuarios inactivos o accesos que hayan dejado de ser necesarios debido a cambios de funciones.
- **Registro de accesos.** En bases de datos críticas, el registro de accesos permite identificar quién ingresó a la información y facilita el seguimiento ante situaciones que requieran análisis.
- **Protección reforzada.** Los datos sensibles pueden requerir permisos especiales y mayores restricciones para su consulta, modificación o descarga.

El principio básico consiste en que cada persona acceda únicamente a la información indispensable para realizar su labor.

2.3. Controles físicos

Los controles físicos son medidas destinadas a proteger documentos, equipos, archivos, espacios y soportes en los que se almacena información personal. Aunque muchas organizaciones concentran sus medidas de seguridad en los entornos digitales, una parte importante de los datos personales continúa almacenada en carpetas, formatos impresos, contratos, hojas de vida, archivos físicos, listados, cuadernos de registro o dispositivos externos.

Estos controles contribuyen a prevenir la pérdida, deterioro, consulta indebida, sustracción o divulgación de información. Son necesarios en oficinas, archivos, puntos de atención, instituciones educativas, consultorios, bodegas documentales, áreas administrativas y cualquier espacio donde se manejen datos personales.

Archivo seguro de documentos

El archivo seguro de documentos permite conservar información física de manera organizada y protegida. Los documentos que contienen datos personales no deben permanecer expuestos en escritorios, zonas de atención, pasillos, impresoras, archivadores abiertos o espacios de acceso general. Las medidas para proteger los archivos físicos pueden organizarse de la siguiente manera:

- **Almacenamiento protegido.** Los documentos deben conservarse en archivadores cerrados y en espacios que reduzcan la posibilidad de consulta por personas no autorizadas.

- **Separación de información sensible.** La información sensible debe mantenerse separada de los documentos generales cuando sus características requieran mayores condiciones de reserva y protección.
- **Custodia y préstamo.** Deben definirse responsables de custodia y controles para el préstamo de expedientes. Esto permite identificar quién tiene los documentos y reducir el riesgo de pérdida.
- **Organización documental.** Mantener los documentos ordenados por proceso, fecha o titular facilita su ubicación y evita la generación de copias innecesarias.
- **Eliminación de documentos.** Los documentos que ya no deban conservarse deben destruirse de manera controlada para evitar que la información permanezca disponible después de finalizar su periodo de conservación.

El archivo seguro también facilita la atención de solicitudes de los titulares y permite sustentar el cumplimiento cuando se requiere ubicar una autorización, contrato, soporte o comunicación.

Restricción de acceso a espacios físicos

La restricción de acceso a espacios físicos permite controlar quién puede ingresar a los lugares donde se conserva información personal. No todas las áreas deben estar disponibles para cualquier trabajador, visitante, proveedor o usuario externo.

Algunos espacios que pueden requerir control son los archivos, oficinas de talento humano, áreas jurídicas, salas de sistemas, bodegas documentales, zonas de atención, centros de correspondencia o lugares donde se imprimen documentos con datos personales. Las medidas de restricción pueden organizarse así:

- **Áreas restringidas.** Los espacios que contienen información personal pueden permanecer cerrados y limitar su ingreso de acuerdo con las necesidades de cada proceso.
- **Control de llaves.** Las llaves u otros mecanismos de ingreso deben asignarse únicamente al personal autorizado, con el fin de limitar el acceso a los espacios protegidos.
- **Registro de visitantes.** El ingreso de visitantes o terceros puede registrarse para mantener control sobre las personas que acceden temporalmente a áreas donde existe información personal.
- **Acompañamiento a terceros.** Cuando un tercero requiera ingresar a un área restringida, el acompañamiento permite reducir el riesgo de acceso a documentos, equipos o información que no corresponda a su actividad.
- **Ubicación segura de archivos.** Los archivadores y demás soportes deben situarse en espacios protegidos, de manera que el acceso a la información responda a una necesidad real del proceso.

Estas medidas permiten limitar el acceso físico a la información y relacionarlo con las funciones o necesidades previamente autorizadas.

Protección de equipos y soportes

Los equipos y soportes físicos también pueden contener datos personales. Computadores, memorias USB, discos externos, celulares institucionales, impresoras, carpetas, cámaras y dispositivos de respaldo deben protegerse para prevenir su pérdida o uso indebido.

Entre las prácticas que pueden generar riesgos se encuentran guardar bases de datos en memorias personales, dejar equipos desbloqueados, abandonar documentos en las bandejas de las impresoras, compartir computadores sin controles o transportar información sin medidas de seguridad. Las principales medidas de protección pueden organizarse así:

- **Bloqueo de equipos.** Los computadores y demás equipos deben bloquearse cuando no estén en uso para reducir el riesgo de acceso a información por parte de personas no autorizadas.
- **Dispositivos de almacenamiento.** Debe evitarse almacenar bases de datos en dispositivos personales. Las memorias USB y los discos externos utilizados en procesos autorizados requieren medidas de protección acordes con la información que contienen.
- **Control de impresiones.** Los documentos con datos personales no deben permanecer abandonados en impresoras o espacios compartidos. Su impresión y manejo requieren medidas que reduzcan la exposición de la información.
- **Custodia y reporte.** Los dispositivos deben conservarse en lugares seguros. La pérdida o el robo de un equipo que contenga información personal debe reportarse para gestionar el riesgo asociado.
- **Eliminación de información.** Antes de desechar o retirar un dispositivo, la información almacenada debe eliminarse de manera controlada para evitar su recuperación o uso posterior.

- **Uso de equipos institucionales.** Los procesos autorizados deben desarrollarse mediante los equipos definidos por la organización, evitando el almacenamiento o traslado informal de información en recursos personales.

La protección física complementa los controles administrativos y técnicos. La aplicación articulada de estos tres tipos de controles permite reducir riesgos y fortalecer la capacidad de la organización para proteger los datos personales.

3. Gestión de solicitudes, incidentes y riesgos

La gestión de solicitudes, incidentes y riesgos permite que la organización responda de manera ordenada ante situaciones relacionadas con los derechos de los titulares, las fallas en la seguridad de la información o los posibles incumplimientos en el tratamiento de datos personales. Este proceso es necesario para demostrar responsabilidad, prevenir sanciones y proteger la información durante todo su ciclo de vida.

Una organización no solo debe recolectar y almacenar datos de manera adecuada; también debe contar con procedimientos para atender consultas, corregir información, suprimir datos cuando corresponda, reportar novedades internas y aplicar acciones de mejora.

La gestión de solicitudes, incidentes y riesgos debe integrarse con las políticas internas de tratamiento de datos, los controles administrativos, técnicos y físicos; y las responsabilidades asignadas a cada área. De esta manera, se evita actuar de forma improvisada cuando un titular presenta una petición o cuando ocurre una situación que compromete la seguridad de la información.

3.1. Atención de derechos de los titulares

La atención de derechos de los titulares consiste en recibir, analizar y responder las solicitudes que realizan las personas sobre sus datos personales. Estos derechos permiten que el titular conozca qué información tiene la organización, solicite su actualización o rectificación, pida la supresión cuando sea procedente o revoque la autorización otorgada para determinadas finalidades.

Para atender estos derechos, la organización debe contar con canales claros, responsables definidos, tiempos de respuesta y evidencias de la gestión realizada. No es suficiente recibir la solicitud; también se debe registrar, revisar, responder y conservar el soporte de la atención brindada.

Los canales de atención pueden incluir correo electrónico, formularios web, línea telefónica, oficina de atención, ventanilla física o sistema de gestión de solicitudes. Lo importante es que el titular conozca dónde puede presentar su petición y que la organización disponga de un procedimiento para tramitarla.

Solicitudes de consulta

Las solicitudes de consulta permiten al titular conocer qué datos personales tiene la organización, para qué los utiliza, de dónde provienen, con quién se comparten y bajo qué condiciones se tratan. Este tipo de solicitud es frecuente cuando una persona desea determinar si su información está registrada o si se utiliza para una finalidad determinada.

Para atender una consulta, la organización debe validar la identidad del solicitante, ubicar la información en sus bases de datos, revisar la finalidad del tratamiento y entregar una respuesta clara. La respuesta no debe incluir datos de otras personas ni información que pueda vulnerar los derechos de terceros. Una solicitud de consulta puede relacionarse con preguntas como:

- ¿Qué datos personales tiene registrados la organización?
- ¿Para qué se utilizan los datos?
- ¿Quién es el responsable del tratamiento?
- ¿La información ha sido compartida con terceros?

- ¿Cuál es la política de tratamiento aplicable?
- ¿Qué autorización respalda el tratamiento?

Atender correctamente las consultas fortalece la transparencia y permite que el titular tenga mayor control sobre su información.

Actualización y rectificación de datos

La actualización y rectificación de datos se presenta cuando el titular solicita corregir información incompleta, inexacta, desactualizada o equivocada. Este derecho es importante porque la información incorrecta puede generar errores en comunicaciones, trámites, pagos, certificaciones, reportes, servicios o decisiones administrativas.

Por ejemplo, un titular puede solicitar la corrección de su número de identificación, dirección, correo electrónico, teléfono, nombre, estado contractual o información asociada a un registro. La organización debe analizar la solicitud, requerir soportes cuando sea necesario y actualizar la base de datos correspondiente.

Para gestionar este tipo de solicitudes, se recomienda:

- Validar la identidad del titular.
- Identificar la base de datos donde se encuentra el registro.
- Verificar el dato que debe actualizarse o corregirse.
- Solicitar soporte cuando aplique.
- Realizar la modificación en los sistemas o archivos correspondientes.
- Informar al titular sobre la actualización realizada.
- Conservar evidencia de la solicitud y de la respuesta.

La actualización oportuna de la información contribuye a mantener bases de datos confiables y reduce los riesgos derivados del uso de datos erróneos.

Supresión y revocatoria de autorización

La supresión y la revocatoria de autorización son mecanismos relacionados con el control que ejerce el titular sobre sus datos personales. Aunque pueden estar vinculados dentro de una misma solicitud, responden a situaciones diferentes y requieren un análisis previo por parte de la organización. Las principales diferencias pueden organizarse de la siguiente manera:

- **Supresión de datos.** Consiste en eliminar datos personales cuando ya no son necesarios, se han tratado de forma indebida o el titular solicita su eliminación y no existe una obligación legal o contractual que exija conservarlos.
- **Revocatoria de autorización.** Se presenta cuando el titular decide retirar el permiso otorgado para una o varias finalidades de tratamiento. Su aplicación depende de la finalidad involucrada y de las obligaciones que justifiquen la conservación de determinados datos.
- **Conservación justificada.** Una solicitud de supresión no implica necesariamente la eliminación inmediata. La organización debe determinar si existen obligaciones legales, contractuales, contables, laborales, administrativas o de defensa jurídica que requieran conservar la información.
- **Revocatoria por finalidad.** El titular puede retirar su autorización para una finalidad específica, como recibir comunicaciones comerciales, sin que esto

implique necesariamente eliminar información requerida para cumplir obligaciones contractuales o legales.

Por lo tanto, antes de atender una solicitud de supresión o revocatoria, la organización debe analizar la finalidad del tratamiento, las obligaciones aplicables y las condiciones que justifican la conservación de la información.

3.2. Gestión de incidentes de seguridad

Un incidente de seguridad es cualquier situación que pueda afectar la confidencialidad, integridad o disponibilidad de los datos personales. Puede presentarse por pérdida de documentos, acceso no autorizado, envío equivocado de información, robo de equipos, eliminación accidental, divulgación indebida, errores en sistemas o uso de canales inseguros.

Gestionar incidentes no significa únicamente reaccionar cuando el problema ya ocurrió. También implica identificar señales de alerta, registrar lo sucedido, evaluar el impacto, aplicar acciones correctivas y prevenir que la situación se repita.

La gestión de incidentes debe ser conocida por las áreas que manejan información personal. Cuando una persona detecta una novedad, debe saber a quién reportarla, qué información debe suministrar y qué acciones debe evitar para no agravar la situación.

Identificación de incidentes

La identificación de incidentes consiste en reconocer situaciones que pueden comprometer los datos personales. Algunas son evidentes, como la pérdida de un computador o el envío de una base de datos a un destinatario equivocado. Otras

pueden ser menos evidentes, como accesos no autorizados, permisos excesivos o documentos expuestos en zonas comunes. Los incidentes pueden agruparse según la situación que compromete la información:

- **Pérdida o robo de equipos.** Se presenta cuando computadores, dispositivos o soportes que contienen información personal quedan fuera del control de la organización, lo que puede facilitar accesos no autorizados.
- **Envíos equivocados.** Ocurre cuando correos electrónicos, archivos o documentos con datos personales son remitidos a destinatarios incorrectos, generando una posible divulgación de información.
- **Acceso no autorizado.** Se produce cuando una persona consulta bases de datos, documentos o sistemas sin contar con los permisos correspondientes o sin que exista una necesidad asociada con sus funciones.
- **Publicación o exposición indebida.** Comprende situaciones en las que listados, contratos, historias laborales u otra información personal quedan disponibles en espacios físicos o digitales sin autorización.
- **Eliminación accidental.** Se presenta cuando registros o archivos son borrados sin intención y pueden afectar la disponibilidad de la información necesaria para los procesos de la organización.
- **Descarga o traslado no autorizado.** Incluye la descarga de bases de datos o el uso de memorias personales para transportar información sin los controles definidos por la organización.

La identificación temprana permite actuar de manera oportuna y reducir el impacto sobre los titulares y la organización.

Registro y reporte interno

Todo incidente debe registrarse, incluso cuando parezca menor. El registro permite establecer qué ocurrió, cuándo sucedió, qué información estuvo comprometida, quién lo detectó, qué áreas participaron y qué acciones se adoptaron.

El reporte interno debe dirigirse al área o persona responsable definida por la organización. Esta función puede corresponder al área de sistemas, jurídica, administrativa, talento humano, seguridad de la información o al responsable designado para la protección de datos. Un registro básico de incidentes debe contener información suficiente para facilitar su análisis y seguimiento:

- **Fecha y hora de detección.** Permite establecer cuándo fue identificado el incidente y facilita reconstruir la secuencia de los hechos relacionados con la situación.
- **Área y persona que reporta.** Identifica el proceso donde ocurrió el incidente y la persona que informó la situación, lo que facilita la comunicación durante el seguimiento.
- **Descripción del incidente.** Precisa qué sucedió, cómo se detectó y cuáles fueron las circunstancias asociadas con el evento. Debe redactarse de forma clara y objetiva.
- **Datos y titulares involucrados.** Permite identificar el tipo de información comprometida y estimar el número de titulares que podrían resultar afectados.
- **Acciones inmediatas.** Registra las medidas adoptadas para contener la situación, proteger la información y evitar que el incidente continúe generando efectos.

- **Responsable y estado del caso.** Permite asignar el seguimiento a una persona o área y establecer si el incidente se encuentra abierto, en análisis o cerrado.
- **Acciones correctivas o preventivas.** Documenta las medidas definidas para corregir las consecuencias del incidente y reducir la posibilidad de que una situación similar se repita.

Registrar los incidentes permite identificar patrones y fortalecer los controles. Si una misma situación se repite, puede ser una señal de falta de capacitación, fallas en los procedimientos, permisos inadecuados o ausencia de controles técnicos.

Acciones correctivas y preventivas

Las acciones correctivas buscan solucionar una situación que ya ocurrió, mientras que las acciones preventivas están orientadas a reducir la posibilidad de que el incidente se repita. Ambas son necesarias para fortalecer la protección de datos personales. La diferencia entre estos dos tipos de acciones puede comprenderse mediante situaciones concretas:

- **Envío de información a un destinatario equivocado.** Como acción correctiva, puede solicitarse la eliminación del mensaje, registrar el incidente y realizar el reporte interno. Como acción preventiva, pueden establecerse revisiones previas de destinatarios, restricciones en envíos masivos o actividades de capacitación.
- **Pérdida de una carpeta con hojas de vida.** La acción correctiva puede orientarse a identificar la información comprometida y procurar su

recuperación. Como prevención, pueden aplicarse controles de préstamo, archivadores cerrados y responsables de custodia.

- **Acceso indebido a una base de datos.** La acción correctiva puede consistir en retirar el acceso no autorizado y analizar la información comprometida. La acción preventiva puede incluir la revisión de perfiles y permisos asignados.

Las acciones deben ser proporcionales al riesgo. Un incidente que involucre datos sensibles, información de menores de edad o un gran volumen de titulares requiere mayor atención que un error menor sin exposición real de información.

3.3. Análisis de riesgos legales

El análisis de riesgos legales permite identificar situaciones que pueden generar incumplimientos relacionados con el tratamiento de datos personales. Estos riesgos pueden derivarse de recolectar datos sin autorización, utilizar información para finalidades no informadas, compartir datos con terceros sin soporte, conservar información innecesaria o no atender solicitudes de los titulares.

Este análisis ayuda a priorizar acciones de mejora. No todos los riesgos tienen el mismo impacto. Algunos pueden afectar únicamente un proceso interno, mientras que otros pueden comprometer los derechos de los titulares, generar reclamaciones, afectar la reputación institucional o exponer a la organización a sanciones. Para analizar los riesgos, se deben considerar tres elementos básicos:

- **Probabilidad de ocurrencia.** Permite establecer qué tan posible es que una situación de riesgo llegue a materializarse durante el tratamiento de los datos personales.

- **Impacto.** Permite determinar las consecuencias que podría generar el riesgo para los titulares, los procesos internos o la organización.
- **Medidas de control existentes.** Permite establecer qué controles administrativos, técnicos o físicos se encuentran implementados para prevenir, reducir o atender el riesgo identificado.

El análisis conjunto de estos elementos facilita la priorización de los riesgos y la definición de acciones de mejora acordes con su nivel de importancia.

Riesgos por uso no autorizado

El uso no autorizado ocurre cuando los datos personales se utilizan para finalidades diferentes de las informadas o aceptadas por el titular. Este riesgo es frecuente cuando las bases de datos se comparten entre áreas sin revisión previa o cuando se utilizan registros antiguos para campañas, comunicaciones o reportes no autorizados. Las situaciones más frecuentes pueden organizarse de la siguiente manera:

- **Uso para una finalidad diferente.** Se presenta cuando datos recolectados para un proceso específico, como una matrícula, se utilizan posteriormente para campañas comerciales u otras actividades que no corresponden a la finalidad inicialmente informada.
- **Comunicaciones sin autorización.** Ocurre cuando se envía publicidad, promociones u otro tipo de comunicación a titulares que no autorizaron expresamente esa finalidad.
- **Entrega de datos a terceros.** Se configura cuando información de empleados, clientes u otros titulares se comparte con terceros sin contar con el soporte correspondiente o sin una finalidad justificada.

- **Uso de fotografías sin autorización.** Se presenta cuando fotografías institucionales se utilizan en publicaciones, campañas u otros medios sin contar con la autorización correspondiente.
- **Consulta sin relación funcional.** Ocurre cuando una persona accede a información personal que no necesita para desarrollar las funciones que le han sido asignadas.

Para reducir este riesgo, se deben revisar las finalidades antes de utilizar una base de datos, separar las autorizaciones según el tipo de tratamiento y restringir los accesos de acuerdo con las funciones del personal.

Riesgos por divulgación indebida

A continuación, se presenta un video que permitirá reconocer las principales situaciones que pueden generar una divulgación indebida de datos personales, así como las medidas de prevención necesarias para proteger la confidencialidad de la información.

Transcripción del podcast. Riesgos por divulgación indebida
Mujer: Un empleado recibe un nuevo correo electrónico en su bandeja de entrada. Al abrir el mensaje, encuentra un reporte confidencial con información sobre los próximos movimientos de personal y las nuevas asignaciones salariales en la empresa.

Hombre: El correo estaba dirigido exclusivamente a la gerencia, pero fue enviado al destinatario equivocado. La información debía mantenerse reservada y terminó disponible para personas que no tenían autorización para consultarla.

Mujer: La divulgación indebida de datos personales se presenta cuando determinada información es conocida, consultada o utilizada por personas que no cuentan con autorización para acceder a ella.

Hombre: Una de las situaciones más comunes es el envío a destinatarios equivocados. También puede presentarse por fallas técnicas, documentos expuestos, permisos de acceso demasiado amplios o por la ausencia de protocolos adecuados de confidencialidad.

Mujer: Las consecuencias dependen del tipo de información que quede expuesta. En este caso hay datos laborales y financieros. También requieren especial protección los datos relacionados con la salud y la información de niños, niñas y adolescentes.

Hombre: Una divulgación indebida a nivel empresarial puede generar consecuencias legales, operativas y reputacionales.

Mujer: Para prevenir estas situaciones, los acuerdos y compromisos de confidencialidad deben establecer con claridad las responsabilidades de trabajadores, contratistas y terceros frente al uso, la custodia y la reserva de la información.

Hombre: También es necesario controlar quién puede acceder a los datos. En los sistemas, las plataformas y los espacios físicos, los permisos deben asignarse de

acuerdo con las funciones de cada persona y con la información que realmente necesita para cumplir su actividad.

Mujer: Al compartir archivos o documentos es importante utilizar canales seguros y revisar cuidadosamente a quién se envía la información. Confirmar los destinatarios y verificar que el contenido corresponda a la finalidad prevista ayuda a evitar exposiciones accidentales.

Hombre: La protección también aplica a los documentos físicos. Los archivos impresos que contienen datos personales deben conservarse en condiciones seguras y evitar que permanezcan expuestos en escritorios, impresoras o zonas comunes.

Mujer: Para que estas medidas funcionen, las personas que manejan información necesitan conocer sus responsabilidades, reconocer las situaciones de riesgo y aplicar los procedimientos establecidos por la organización.

Hombre: Las empresas también deben abrir espacios de capacitación sobre este tema como parte de sus estrategias de prevención.

Mujer: Prevenir la divulgación indebida requiere combinar controles técnicos y organizacionales con prácticas responsables. Así se reduce la posibilidad de que los datos personales sean conocidos, compartidos o utilizados por personas que no están autorizadas.

Riesgos por falta de evidencias

La falta de evidencias ocurre cuando la organización no puede demostrar que actuó correctamente frente al tratamiento de datos personales. Puede existir

autorización, atención de solicitudes o aplicación de controles, pero, si no se cuenta con los soportes correspondientes, se dificulta demostrar el cumplimiento. Las principales evidencias pueden organizarse según su función:

- **Autorizaciones y políticas.** Las autorizaciones físicas o digitales y las políticas de tratamiento permiten sustentar las condiciones bajo las cuales la organización recolecta y utiliza los datos personales.
- **Atención de derechos.** Los registros de consultas y reclamos, junto con los soportes de actualización o supresión, permiten documentar la forma en que la organización atiende las solicitudes de los titulares.
- **Gestión de bases de datos.** El inventario de bases de datos permite identificar la información tratada, los procesos relacionados y las condiciones establecidas para su administración.
- **Formación y confidencialidad.** Las actas de capacitación y los acuerdos de confidencialidad permiten sustentar las acciones realizadas para orientar al personal y definir responsabilidades frente al manejo de la información.
- **Gestión de incidentes y controles.** Los registros de incidentes y las evidencias de controles aplicados permiten documentar las medidas utilizadas para proteger la información y atender situaciones que puedan comprometerla.
- **Comunicaciones con titulares.** Las comunicaciones enviadas al titular permiten respaldar respuestas, informaciones y actuaciones realizadas durante la gestión de sus datos personales.

Las evidencias deben conservarse de manera organizada, protegida y disponible para consulta interna cuando sean requeridas. No se trata de acumular documentos sin control, sino de conservar soportes útiles que permitan sustentar la gestión realizada.

4. Ejercicios prácticos de aplicación organizacional

Los ejercicios prácticos de aplicación organizacional permiten aplicar los conceptos de protección de datos personales en situaciones cercanas al funcionamiento real de una organización. Su propósito es fortalecer la capacidad para identificar los datos tratados, revisar autorizaciones, reconocer riesgos y proponer acciones de mejora orientadas a proteger la información personal.

En este apartado se plantean tres contextos de aplicación: una empresa comercial, una institución educativa y un área de talento humano. Cada caso permite analizar el tratamiento de datos personales desde procesos diferentes, teniendo en cuenta las finalidades, los titulares, las autorizaciones, los controles y los riesgos asociados. Los contextos de aplicación se organizan de la siguiente manera:

- **Empresa comercial.** Permite analizar el tratamiento de datos de clientes, la revisión de autorizaciones para finalidades comerciales y las acciones necesarias para fortalecer campañas y comunicaciones.
- **Institución educativa.** Se centra en el tratamiento de información de estudiantes, acudientes y demás integrantes de la comunidad educativa, con especial atención a los datos de niños, niñas y adolescentes.
- **Área de talento humano.** Aborda el manejo de hojas de vida, contratos, datos laborales y sensibles, así como la protección de archivos físicos y digitales relacionados con trabajadores y aspirantes.

Estos casos permiten trasladar los conceptos de protección de datos personales a situaciones organizacionales concretas.

4.1. Caso práctico: empresa comercial

Una empresa comercial recolecta datos personales de clientes para gestionar ventas, enviar información sobre productos, atender garantías, realizar procesos de facturación y responder solicitudes. En este tipo de organización, el tratamiento de datos suele realizarse mediante formularios físicos, plataformas digitales, bases de datos de clientes, correos electrónicos, redes sociales, sistemas de facturación y campañas comerciales.

El principal cuidado consiste en determinar que los datos recolectados sean necesarios para la finalidad informada y que exista autorización cuando se utilicen para comunicaciones comerciales, promociones, encuestas o campañas de fidelización. No todos los datos entregados por un cliente pueden utilizarse libremente para cualquier actividad de mercadeo.

Diagnóstico de datos de clientes

El diagnóstico de datos de clientes inicia con la identificación de los datos personales que la empresa conserva sobre sus clientes. Estos pueden incluir nombre, documento de identidad, teléfono, correo electrónico, dirección, historial de compras, preferencias, solicitudes, reclamos o información de pagos. Para desarrollar el ejercicio, la revisión de la base de datos comercial puede organizarse mediante los siguientes criterios:

- **Datos personales tratados.** Se deben identificar los datos que contiene la base y establecer si corresponden con las necesidades reales del proceso comercial. Esto permite reconocer información innecesaria o excesiva.

- **Finalidad del tratamiento.** Cada dato recolectado debe relacionarse con una finalidad definida, como facturación, atención de garantías, gestión de ventas o comunicaciones comerciales.
- **Autorización.** Se debe determinar si existe soporte para el tratamiento y, cuando corresponda, si la autorización cubre específicamente las finalidades comerciales aplicadas.
- **Actualización de la información.** La revisión debe permitir identificar datos desactualizados, incompletos o que ya no resulten necesarios para el proceso.
- **Acceso a la base.** Es necesario establecer quiénes pueden consultar, modificar o descargar la información y si esos permisos corresponden con las funciones asignadas.
- **Evidencias y conservación.** Se debe determinar si la empresa conserva evidencia de la autorización y si ha definido tiempos de conservación para la información almacenada.

Este diagnóstico permite reconocer si la base de clientes responde a una finalidad clara o si existen datos innecesarios, desactualizados o utilizados sin soporte suficiente.

Revisión de autorizaciones comerciales

La revisión de autorizaciones comerciales permite determinar si los clientes aceptaron recibir información publicitaria, promociones, novedades, encuestas o comunicaciones por medios electrónicos. Esta revisión es importante porque una base creada para facturación o entrega de productos no debe utilizarse automáticamente para campañas comerciales.

La autorización debe indicar de forma clara la finalidad comercial. También debe permitir al titular conocer sus derechos y los canales disponibles para solicitar actualización, supresión o revocatoria. Los elementos que deben analizarse pueden organizarse de la siguiente manera:

- **Identificación del responsable.** La autorización debe permitir reconocer qué organización realiza el tratamiento y quién asume la responsabilidad sobre los datos recolectados.
- **Finalidad comercial.** Debe explicar con claridad si la información será utilizada para promociones, campañas, encuestas, comunicaciones u otras actividades de naturaleza comercial.
- **Derechos del titular.** El titular debe recibir información sobre los derechos que puede ejercer respecto de sus datos personales durante el tratamiento.
- **Canales de atención.** La autorización debe señalar los mecanismos disponibles para presentar consultas, solicitar actualizaciones, pedir supresión o revocar autorizaciones cuando corresponda.
- **Evidencia de aceptación.** La organización debe conservar un soporte que permita demostrar que el cliente otorgó la autorización y establecer cuándo se produjo dicha aceptación.
- **Separación de finalidades.** Las finalidades contractuales y publicitarias deben diferenciarse para evitar que la información recolectada con un propósito se utilice automáticamente para otro distinto.

Si la autorización no cumple estos elementos, se debe proponer una mejora en el formulario o en el mecanismo de registro.

Propuesta de mejora para campañas

Una campaña comercial debe utilizar únicamente datos autorizados para esa finalidad. Antes de enviar mensajes, correos electrónicos, realizar llamadas o remitir promociones, la empresa debe determinar que la base de datos esté actualizada y que los titulares hayan aceptado recibir comunicaciones comerciales. Las acciones de mejora pueden estructurarse así:

- **Actualización de autorizaciones.** Es necesario ajustar los formularios cuando no diferencien las finalidades o no permitan conservar evidencia suficiente de la aceptación del titular.
- **Separación de finalidades.** La finalidad relacionada con la compra o prestación del servicio debe mantenerse diferenciada de la finalidad publicitaria o promocional.
- **Depuración de la base.** Deben identificarse clientes inactivos, datos desactualizados y registros que ya no resulten necesarios para las actividades comerciales.
- **Gestión de revocatorias.** Conviene mantener identificados los titulares que hayan retirado su autorización para comunicaciones comerciales, con el fin de evitar nuevos contactos no autorizados.
- **Control de acceso.** La base comercial debe quedar disponible únicamente para las personas que requieran utilizarla de acuerdo con sus funciones.
- **Evidencias y canales de retiro.** La empresa debe conservar soporte de la autorización y de las comunicaciones realizadas, además de informar un canal para dejar de recibir contenidos comerciales.

Estas acciones permiten fortalecer el uso responsable de la información de los clientes durante el desarrollo de campañas comerciales.

4.2. Caso práctico: institución educativa

Una institución educativa maneja datos personales de estudiantes, acudientes, docentes, personal administrativo y proveedores. En este contexto, la protección de datos requiere especial cuidado porque puede incluir información de niños, niñas y adolescentes, registros académicos, datos familiares, fotografías, videos, datos de salud y documentos de identificación.

El tratamiento de esta información debe estar relacionado con finalidades educativas, administrativas, académicas, disciplinarias, de bienestar, seguridad o comunicación institucional. Además, cuando se trate de menores de edad, se debe actuar con mayor responsabilidad y respetar el interés superior del menor.

Tratamiento de datos de estudiantes

Los datos de estudiantes pueden encontrarse en matrículas, observadores, boletines, plataformas académicas, listados de asistencia, registros de convivencia, autorizaciones de salida, encuestas, certificados, comunicaciones con acudientes y bases institucionales. Para analizar este caso, se deben considerar los siguientes aspectos:

- **Datos recolectados.** Se debe identificar qué información se solicita durante la matrícula y cuál se incorpora posteriormente en el desarrollo del proceso académico.

- **Acceso a la información.** Es necesario determinar quiénes pueden consultar los datos de los estudiantes y si ese acceso corresponde con las funciones asignadas.
- **Almacenamiento.** Debe identificarse dónde se conservan los registros académicos y administrativos, tanto en soportes físicos como en plataformas o sistemas institucionales.
- **Entrega a acudientes o terceros.** La institución debe establecer qué información puede compartirse, con quién y bajo qué condiciones, evitando la entrega de datos de otros estudiantes.
- **Autorizaciones.** Se deben identificar los soportes que respaldan los tratamientos realizados, especialmente cuando se utilicen fotografías, videos u otra información que requiera autorización.
- **Medidas de protección.** Deben aplicarse controles para evitar la exposición de notas, listados, datos familiares o información sensible en espacios de acceso general.

La institución también debe proteger las plataformas académicas mediante usuarios, contraseñas y perfiles de acceso.

Protección de datos de menores de edad

Los datos de menores de edad requieren protección reforzada. Su tratamiento debe realizarse con autorización de los representantes legales cuando corresponda y responder a finalidades legítimas relacionadas con el servicio educativo o institucional.

Una situación frecuente es el uso de fotografías y videos en redes sociales, páginas web, carteleras, eventos o material promocional. Antes de publicar este tipo de

contenido, la institución debe contar con autorización clara, informar la finalidad y evitar exponer información que pueda afectar la seguridad o intimidad del menor. Las buenas prácticas pueden organizarse de la siguiente manera:

- **Recolección necesaria.** Deben solicitarse únicamente los datos necesarios para cumplir las finalidades educativas, administrativas o institucionales correspondientes.
- **Autorizaciones de acudientes.** La institución debe conservar los soportes relacionados con la autorización cuando corresponda, especialmente en tratamientos que impliquen fotografías, videos u otros usos específicos.
- **Acceso restringido.** La información académica, médica o familiar debe estar disponible únicamente para las personas que requieran consultarla por razón de sus funciones.
- **Uso de imágenes.** Las fotografías o videos de menores no deben publicarse sin la autorización correspondiente ni utilizarse para finalidades distintas de las informadas.
- **Plataformas y comunicaciones.** Los permisos en plataformas académicas deben revisarse y las comunicaciones relacionadas con estudiantes deben gestionarse mediante canales institucionales.
- **Capacitación del personal.** Docentes y personal administrativo deben conocer las medidas aplicables al tratamiento de información de niños, niñas y adolescentes.

Estas medidas permiten reforzar la protección de la información de menores de edad en los diferentes procesos institucionales.

Control de acceso a información académica

El control de acceso a información académica permite garantizar que únicamente las personas autorizadas consulten los registros de los estudiantes. No todos los docentes, administrativos o terceros deben acceder a toda la información institucional.

Por ejemplo, un docente puede consultar información académica de su grupo, pero no necesariamente datos familiares, médicos o financieros. El área administrativa puede gestionar matrículas y pagos, pero no debe divulgar información académica sin autorización. Los acudientes pueden recibir información del estudiante a su cargo, pero no datos de otros estudiantes. Las medidas de control pueden organizarse así:

- Usuarios individuales: cada persona debe contar con un acceso propio a las plataformas institucionales para relacionar las acciones realizadas con un usuario determinado.
- Perfiles según funciones: los permisos deben asignarse de acuerdo con las responsabilidades de docentes, administrativos y demás personas que intervienen en el proceso.
- Restricción de descargas: la descarga de reportes debe limitarse cuando no sea necesaria para el desarrollo de las funciones asignadas.
- Revisión de permisos: los accesos a las plataformas académicas deben revisarse periódicamente para retirar permisos innecesarios o desactualizados.
- Protección de documentos: los listados y documentos físicos gestionados en secretaría o coordinación deben mantenerse bajo control y evitar su circulación mediante canales informales.

- Entrega de información: la entrega de certificados o reportes debe registrarse cuando sea necesario para conservar evidencia de quién recibió la información.

La definición de permisos según las funciones permite limitar el acceso a la información académica y reducir los riesgos de divulgación indebida.

4.3. Caso práctico: área de talento humano

El área de talento humano maneja información personal de aspirantes, empleados, contratistas, practicantes y exempleados. Esta información puede incluir hojas de vida, documentos de identificación, contratos, certificados, datos bancarios, afiliaciones, incapacidades, evaluaciones, registros disciplinarios, información familiar y datos de salud ocupacional.

Por la naturaleza de estos datos, talento humano debe aplicar controles administrativos, técnicos y físicos. También debe limitar el acceso a la información, conservar soportes de autorización, definir tiempos de retención documental y garantizar la confidencialidad.

Manejo de hojas de vida y contratos

Las hojas de vida contienen información personal, académica, laboral, familiar y de contacto. Por esta razón, no deben circular libremente dentro de la organización ni conservarse indefinidamente sin una finalidad.

Durante los procesos de selección, la organización debe informar al aspirante para qué se recolecta su información, durante cuánto tiempo se conservará y cómo puede ejercer sus derechos. Cuando el proceso finaliza, se debe definir si la hoja de

vida será eliminada, archivada temporalmente o conservada para futuras convocatorias con la correspondiente autorización.

En el caso de los contratos, se debe proteger la información relacionada con identificación, salario, cargo, funciones, afiliaciones, datos bancarios y documentos de soporte. Estos archivos deben permanecer bajo custodia del área responsable y no deben compartirse con personas que no intervengan en el proceso laboral o contractual. Las principales condiciones de manejo pueden organizarse de esta manera:

- **Hojas de vida de aspirantes.** Deben recolectarse para una finalidad definida y conservarse únicamente durante el tiempo que resulte pertinente. Si se mantienen para futuras convocatorias, debe existir el soporte correspondiente.
- **Información contractual.** Los contratos y sus documentos asociados pueden contener datos de identificación, salario, afiliaciones y datos bancarios, por lo que requieren medidas de custodia y acceso restringido.
- **Circulación interna.** Las hojas de vida y los contratos no deben compartirse con personas que no intervengan en el proceso de selección, contratación o gestión laboral.
- **Conservación.** La organización debe establecer qué información se mantiene, durante cuánto tiempo y bajo qué condiciones, evitando la conservación indefinida sin una finalidad.

Estas medidas permiten limitar el uso y circulación de la información laboral a las necesidades reales del proceso.

Protección de datos laborales y sensibles

En talento humano pueden tratarse datos sensibles, especialmente aquellos relacionados con salud, incapacidades, restricciones médicas, exámenes ocupacionales, condiciones especiales, biometría o información familiar. Estos datos requieren mayor confidencialidad y acceso restringido.

No toda persona dentro de la organización debe conocer esta información. Su tratamiento debe limitarse al cumplimiento de obligaciones laborales, administrativas, legales o relacionadas con la seguridad y salud en el trabajo. Las principales medidas pueden organizarse así:

- **Separación de información.** Los expedientes laborales pueden mantenerse diferenciados de la información médica o sensible cuando esta requiera mayores condiciones de reserva.
- **Acceso restringido.** La consulta debe limitarse al personal autorizado y responder a una necesidad relacionada con las funciones asignadas.
- **Canales seguros.** Debe evitarse el envío de incapacidades u otros documentos sensibles mediante canales inseguros o mecanismos no autorizados por la organización.
- **Protección documental.** Los documentos físicos y digitales deben conservarse en carpetas, sistemas o repositorios protegidos frente a accesos no autorizados.
- **Uso limitado.** La información debe utilizarse exclusivamente para las finalidades laborales, administrativas o legales correspondientes, sin divulgar condiciones de salud u otros datos sensibles.

- **Capacitación.** El personal encargado del proceso debe conocer las responsabilidades aplicables al tratamiento de información laboral y sensible.

La aplicación de estas medidas permite fortalecer la confidencialidad y limitar el tratamiento de información laboral y sensible a las finalidades correspondientes.

Medidas para archivo físico y digital

El archivo físico y digital en talento humano debe organizarse de forma segura. Los documentos físicos deben permanecer en archivadores cerrados, con responsables de custodia y controles de préstamo. Los archivos digitales deben almacenarse en carpetas protegidas, sistemas institucionales o repositorios con permisos definidos.

No es recomendable guardar información laboral en computadores personales, memorias USB sin control, correos electrónicos personales o carpetas compartidas sin restricciones. Tampoco deben dejarse documentos impresos sobre escritorios, impresoras o zonas comunes. Las medidas para ambos tipos de archivo pueden estructurarse de la siguiente manera:

- **Archivo físico.** Los documentos deben conservarse en archivadores cerrados, con responsables definidos y controles que permitan gestionar el préstamo de expedientes.
- **Archivo digital.** La información debe almacenarse en sistemas institucionales, carpetas protegidas o repositorios con permisos asignados según las funciones.
- **Dispositivos personales.** Debe evitarse guardar información laboral en computadores personales, memorias USB u otros dispositivos que no cuenten con los controles definidos por la organización.

- **Carpetas compartidas.** Los repositorios compartidos deben contar con restricciones de acceso que impidan la consulta o modificación de información por personas no autorizadas.
- **Documentos impresos.** Los documentos con datos personales no deben permanecer expuestos en escritorios, impresoras o espacios de acceso general.

La organización segura de los archivos físicos y digitales complementa los demás controles aplicados por talento humano y contribuye a proteger la información durante su conservación y uso.

5. Plan de mejora para la protección de datos personales

El plan de mejora para la protección de datos personales es una herramienta que permite organizar las acciones necesarias para corregir debilidades, reducir riesgos y fortalecer el cumplimiento en el tratamiento de la información. Este plan se construye a partir del diagnóstico realizado, los hallazgos identificados, los controles existentes y las necesidades detectadas en cada proceso de la organización.

Un plan de mejora no debe convertirse en un documento extenso sin aplicación práctica. Debe ser claro, realista y útil para orientar la toma de decisiones. Su propósito es definir qué se debe mejorar, quién será responsable, qué acciones se implementarán, qué evidencias se conservarán y cómo se realizará el seguimiento.

La elaboración de este plan contribuye a que la organización actúe de manera preventiva frente a posibles incumplimientos. También permite fortalecer la cultura de protección de datos personales, mejorar los procedimientos internos, actualizar documentos, proteger las bases de datos y responder de manera adecuada a los derechos de los titulares.

5.1. Elaboración del diagnóstico final

El diagnóstico final reúne los resultados obtenidos durante la revisión de bases de datos, formularios, autorizaciones, políticas, controles, solicitudes, incidentes y riesgos. Su finalidad es presentar una perspectiva clara del estado de la organización frente al tratamiento de datos personales.

Este diagnóstico debe incluir los aspectos que funcionan adecuadamente y aquellos que requieren mejora. No se trata únicamente de señalar errores, sino de

identificar oportunidades para fortalecer la gestión de la información personal. Los elementos del diagnóstico pueden organizarse así:

- **Bases de datos y tipos de información.** Se deben identificar las bases existentes y los tipos de datos tratados para determinar qué información administra la organización y en qué procesos se utiliza.
- **Finalidades y autorizaciones.** Es necesario relacionar cada tratamiento con su finalidad y establecer si existen los soportes de autorización correspondientes cuando sean requeridos.
- **Políticas y responsables.** La revisión debe establecer si existen políticas vigentes y si las responsabilidades internas frente al tratamiento están claramente asignadas.
- **Controles implementados.** Se deben considerar los controles administrativos, técnicos y físicos aplicados para proteger la información durante su ciclo de tratamiento.
- **Solicitudes e incidentes.** El diagnóstico debe integrar las solicitudes de titulares y los incidentes registrados, con el fin de identificar dificultades recurrentes o necesidades de mejora.
- **Riesgos y evidencias.** Se deben consolidar los riesgos identificados y los soportes disponibles para demostrar las acciones realizadas por la organización.

La revisión integral de estos elementos permite consolidar los resultados del diagnóstico y establecer las prioridades que orientarán el plan de mejora.

Matriz de hallazgos

La matriz de hallazgos permite organizar las situaciones identificadas durante el diagnóstico. Cada hallazgo debe describirse de manera clara e indicar el área afectada, el riesgo asociado y la acción de mejora recomendada.

Un hallazgo puede corresponder a una debilidad documental, un riesgo operativo, una ausencia de control, una autorización incompleta, una política desactualizada o una práctica que requiera ajuste. Lo importante es que su identificación permita tomar decisiones concretas. La matriz puede estructurarse a partir de los siguientes elementos:

- **Hallazgo.** Describe de manera concreta la situación identificada durante el diagnóstico y permite precisar la debilidad, ausencia de control o práctica que requiere ajuste.
- **Área afectada.** Identifica el área, proceso o dependencia relacionada con el hallazgo y facilita la asignación posterior de responsabilidades.
- **Riesgo asociado.** Precisa la posible consecuencia derivada del hallazgo, especialmente cuando puede comprometer el tratamiento adecuado o la protección de los datos personales.
- **Acción de mejora.** Define la medida recomendada para corregir la situación, fortalecer el control existente o reducir el riesgo identificado durante el diagnóstico.

Esta organización facilita la relación entre los hallazgos identificados y las acciones que deben incorporarse al plan de mejora.

Priorización de riesgos

La priorización de riesgos permite definir cuáles situaciones deben atenderse primero. No todos los hallazgos tienen el mismo impacto ni requieren el mismo nivel de urgencia. Algunos pueden resolverse mediante ajustes simples, mientras que otros requieren intervención inmediata por el tipo de datos comprometidos o por la posibilidad de afectar los derechos de los titulares. Para establecer la prioridad, se deben considerar tres elementos principales:

- **Probabilidad.** Permite establecer la posibilidad de que el riesgo identificado llegue a materializarse durante el tratamiento de los datos personales.
- **Impacto.** Permite determinar las consecuencias que podría generar la materialización del riesgo para los titulares, los procesos o la organización.
- **Tipo de datos involucrados.** Permite considerar la naturaleza de la información comprometida. Los riesgos relacionados con datos sensibles, menores de edad, divulgación indebida o falta de autorización requieren mayor atención.

La priorización permite organizar las acciones de mejora en el corto, mediano y largo plazo. De esta manera, se evita que el plan se convierta en una lista general de actividades sin un orden de atención ni responsables definidos.

Evidencias de cumplimiento

Las evidencias de cumplimiento son los soportes que permiten demostrar que la organización ha realizado acciones para proteger los datos personales. Estas evidencias pueden ser físicas o digitales y deben conservarse de manera organizada. Para facilitar su gestión, pueden agruparse de acuerdo con la acción que respaldan:

- **Autorizaciones y políticas.** Incluyen autorizaciones de tratamiento y políticas publicadas o socializadas que permiten sustentar las condiciones definidas para el manejo de la información.
- **Gestión de bases de datos.** El inventario de bases de datos permite identificar la información tratada, los procesos relacionados y las condiciones de administración.
- **Atención de derechos.** Los registros de consultas y reclamos, así como los formatos de actualización, rectificación o supresión, permiten documentar la atención brindada a los titulares.
- **Capacitación y confidencialidad.** Las actas, listados de capacitación y acuerdos de confidencialidad permiten sustentar las acciones desarrolladas con el personal que maneja información personal.
- **Gestión de incidentes y riesgos.** Los registros de incidentes, matrices de riesgos y soportes de acciones correctivas permiten documentar situaciones identificadas y las respuestas implementadas.
- **Controles y comunicaciones.** Las evidencias de controles de acceso y las comunicaciones remitidas a los titulares respaldan las actuaciones desarrolladas durante la gestión de la información.

Contar con evidencias no significa acumular documentos sin control. La organización debe conservar soportes útiles, actualizados y relacionados directamente con las acciones implementadas.

5.2. Diseño de acciones de mejora

El diseño de acciones de mejora consiste en definir actividades concretas para corregir los hallazgos identificados. Estas acciones deben ser realizables, medibles y

coherentes con los riesgos encontrados. Para formular una acción de mejora, deben considerarse los siguientes elementos:

- **Situación que requiere corrección:** permite precisar qué hallazgo, debilidad o riesgo será intervenido mediante la acción propuesta.
- **Justificación:** explica por qué es necesario realizar la acción y qué riesgo o necesidad pretende atender.
- **Responsable:** define la persona, área o proceso encargado de ejecutar y realizar seguimiento a la actividad.
- **Recursos:** identifica los recursos humanos, tecnológicos, documentales o administrativos necesarios para implementar la acción.
- **Plazo:** establece el periodo en el que debe ejecutarse la actividad y facilita el seguimiento a su cumplimiento.
- **Evidencia:** define el soporte que permitirá demostrar que la acción fue realizada.
- **Efectividad:** permite determinar cómo se establecerá si la medida implementada contribuyó a corregir el hallazgo o reducir el riesgo.

Las acciones de mejora pueden ser administrativas, técnicas o de capacitación. Su aplicación articulada permite integrar documentos, controles tecnológicos, responsables definidos y personal capacitado para fortalecer la protección de datos personales.

Acciones administrativas

Las acciones administrativas están relacionadas con políticas, procedimientos, formatos, responsables, controles internos y documentación. Permiten organizar la

gestión de los datos personales y definir reglas claras para las diferentes áreas de la organización. Las principales acciones administrativas pueden organizarse de esta manera:

- **Políticas y autorizaciones.** Incluyen la actualización de la política de tratamiento y la creación o ajuste de formatos de autorización para mantenerlos acordes con las finalidades aplicadas.
- **Inventario y responsables.** Comprenden la elaboración del inventario de bases de datos y la asignación de responsables para facilitar su administración y seguimiento.
- **Atención e incidentes.** Incluyen procedimientos para consultas y reclamos, así como formatos que permitan registrar y gestionar incidentes relacionados con información personal.
- **Conservación y eliminación.** Permiten definir tiempos de conservación documental y procedimientos para eliminar información de manera segura cuando ya no deba mantenerse.
- **Terceros y confidencialidad.** Comprenden la revisión de contratos con encargados del tratamiento y la formalización de acuerdos de confidencialidad cuando corresponda.

Estas acciones fortalecen la organización documental y permiten establecer responsabilidades y procedimientos claros para el tratamiento de datos personales.

Acciones técnicas

Las acciones técnicas están relacionadas con herramientas, sistemas, accesos, seguridad digital y protección de archivos electrónicos. Son necesarias para prevenir

accesos no autorizados, pérdidas, modificaciones o divulgación indebida de información. Las principales acciones pueden agruparse así:

- **Gestión de accesos.** Incluye la creación de perfiles según funciones, el retiro de usuarios inactivos y la revisión periódica de permisos en plataformas institucionales.
- **Autenticación.** La activación del doble factor de autenticación, cuando sea posible, fortalece el control de ingreso a sistemas que contienen información personal.
- **Copias y cifrado.** Las copias de seguridad periódicas y el cifrado de archivos con datos sensibles permiten fortalecer la disponibilidad y confidencialidad de la información.
- **Descargas y dispositivos.** Restringir descargas y controlar el uso de dispositivos externos reduce el riesgo de copias, pérdidas o traslados no autorizados de bases de datos.
- **Carpetas y registros de acceso.** Las carpetas compartidas deben protegerse mediante permisos, y los accesos a bases críticas pueden registrarse para facilitar el seguimiento.

Estas medidas complementan las acciones administrativas y permiten fortalecer la seguridad de la información almacenada o tratada mediante recursos tecnológicos.

Acciones de capacitación

Las acciones de capacitación buscan fortalecer el conocimiento y la responsabilidad del personal que maneja datos personales. Muchas fallas pueden producirse por desconocimiento, descuido o uso inadecuado de la información.

La capacitación debe ser práctica y estar relacionada con las funciones de cada área. No basta con explicar la norma; también es necesario presentar casos, riesgos y buenas prácticas aplicables al trabajo diario. Los contenidos pueden agruparse en los siguientes ejes:

- **Principios y derechos.** Incluye los principios de protección de datos personales y los derechos de los titulares para que el personal comprenda las bases del tratamiento responsable.
- **Autorizaciones y finalidades.** Permite fortalecer la comprensión sobre la relación entre la autorización otorgada, la finalidad informada y el uso permitido de los datos.
- **Datos sensibles y menores de edad.** Aborda las condiciones especiales de manejo de información que requieren mayores medidas de protección y confidencialidad.
- **Seguridad y confidencialidad.** Incluye buenas prácticas para el uso de bases de datos, manejo de información reservada y protección de archivos, formularios y correos electrónicos.
- **Solicitudes e incidentes.** Permite orientar al personal sobre la atención de consultas y reclamos, así como sobre el reporte oportuno de incidentes relacionados con datos personales.

La capacitación periódica contribuye a que las medidas establecidas por la organización se incorporen a las actividades cotidianas del personal encargado del tratamiento de datos.

5.3. Presentación del plan de protección de datos

La presentación del plan de protección de datos permite comunicar los resultados del diagnóstico y las acciones de mejora propuestas. Esta presentación debe ser clara, organizada y comprensible para las personas responsables de tomar decisiones dentro de la organización.

El plan debe incluir los hallazgos principales, los riesgos identificados, las acciones priorizadas, los responsables, los tiempos de ejecución y las evidencias esperadas. También debe explicar por qué las acciones propuestas contribuyen a prevenir sanciones, proteger los derechos de los titulares y mejorar la gestión interna.

Una presentación organizada del plan facilita la aprobación de recursos, la asignación de responsabilidades y el seguimiento de las acciones. Además, permite que las diferentes áreas comprendan su papel en la protección de datos personales.

Estructura del plan de mejora

El plan de mejora debe tener una estructura sencilla y funcional que permita comprender el diagnóstico, las acciones propuestas y el seguimiento correspondiente. La estructura básica puede incluir los siguientes componentes:

- **Objetivo del plan.** Define qué se busca mejorar mediante la implementación del plan y orienta las acciones relacionadas con la protección de datos personales.
- **Alcance del plan.** Precisa las áreas, procesos o bases de datos que serán intervenidos y delimita el campo de aplicación de las acciones propuestas.

- **Resumen del diagnóstico.** Integra los principales resultados obtenidos durante la revisión de bases de datos, autorizaciones, políticas, controles, solicitudes, incidentes y riesgos.
- **Hallazgos principales.** Reúne las situaciones que requieren atención y que sirven como punto de partida para establecer las acciones de mejora.
- **Riesgos identificados.** Contiene los riesgos asociados con los hallazgos y permite establecer su nivel de atención de acuerdo con la probabilidad, el impacto y el tipo de datos involucrados.
- **Acciones de mejora.** Define las actividades concretas que se implementarán para corregir debilidades, reducir riesgos y fortalecer los controles existentes.
- **Responsables.** Identifica las áreas o personas encargadas de ejecutar, coordinar o realizar seguimiento a cada acción definida.
- **Plazos.** Establece los tiempos previstos para desarrollar las acciones y permite organizar su ejecución en el corto, mediano o largo plazo.
- **Evidencias esperadas.** Precisa los soportes físicos o digitales que permitirán demostrar la implementación y cumplimiento de las acciones propuestas.
- **Indicadores de seguimiento.** Permite medir el avance de las acciones y determinar si las medidas implementadas contribuyen a reducir los riesgos identificados.
- **Recomendaciones finales.** Integra orientaciones para mantener las acciones implementadas y fortalecer de manera continua la protección de datos personales.

Esta estructura permite relacionar el diagnóstico con las acciones, responsables, plazos y evidencias necesarias para facilitar la ejecución y el seguimiento del plan.

Recomendaciones organizacionales

Las recomendaciones organizacionales son orientaciones que ayudan a mantener y fortalecer la protección de datos personales. Estas deben ser realistas y adaptarse al contexto de la entidad. Las recomendaciones pueden agruparse por su propósito:

- **Actualización de información y documentos.** Mantener actualizado el inventario de bases de datos y revisar periódicamente las autorizaciones, finalidades y documentos asociados con el tratamiento.
- **Formación del personal.** Capacitar de manera periódica a las personas que manejan información personal para fortalecer el conocimiento de sus responsabilidades.
- **Control de accesos.** Restringir los accesos físicos y digitales de acuerdo con las funciones y revisar periódicamente los permisos otorgados.
- **Evidencias y atención de titulares.** Conservar soportes de cumplimiento y atender oportunamente las solicitudes presentadas por los titulares.
- **Incidentes y depuración.** Registrar los incidentes, aplicar acciones correctivas y depurar la información que haya dejado de ser necesaria.
- **Terceros y evaluación de controles.** Revisar los contratos con terceros que traten datos y evaluar periódicamente la efectividad de los controles implementados.

Estas recomendaciones deben integrarse en la gestión diaria de la organización. La protección de datos personales no debe asumirse como una actividad aislada, sino como parte de los procesos administrativos, tecnológicos, jurídicos y operativos.

Seguimiento y mejora continua

El seguimiento y la mejora continua permiten determinar si las acciones definidas fueron implementadas y si contribuyeron a reducir los riesgos identificados. Sin un seguimiento periódico, el plan puede convertirse en un documento sin aplicación práctica. Para realizar el seguimiento, pueden utilizarse indicadores asociados con diferentes aspectos de la gestión:

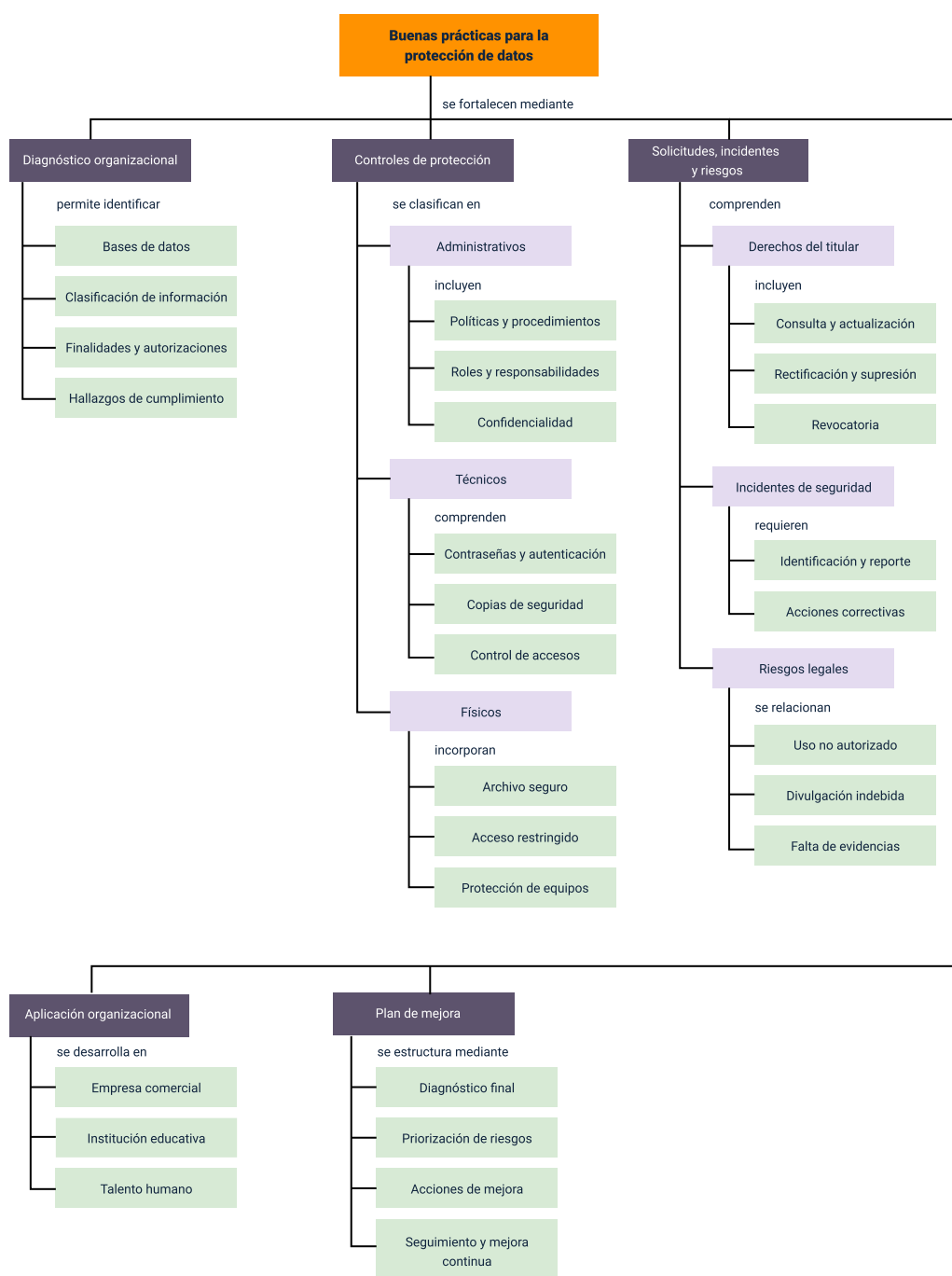
- **Autorizaciones.** El número de autorizaciones actualizadas permite establecer el avance en la revisión y ajuste de los soportes relacionados con el tratamiento de datos.
- **Capacitación.** La cantidad de personas capacitadas permite realizar seguimiento a la cobertura de las actividades dirigidas al personal.
- **Inventario de bases de datos.** El porcentaje de bases inventariadas permite determinar el nivel de avance en la identificación y organización de la información tratada.
- **Control de accesos.** El número de accesos revisados permite realizar seguimiento a la actualización de permisos y perfiles asignados.
- **Solicitudes de titulares.** La cantidad de solicitudes atendidas permite controlar la gestión de consultas, actualizaciones, supresiones u otras peticiones relacionadas con datos personales.
- **Incidentes.** El número de incidentes registrados y cerrados permite identificar situaciones reportadas y determinar su nivel de gestión.
- **Actualización documental.** La cantidad de políticas o formatos actualizados permite realizar seguimiento a las acciones administrativas definidas en el plan.

- **Cumplimiento del plan.** El número de acciones de mejora cumplidas permite determinar el avance general de las actividades programadas.

La mejora continua implica revisar periódicamente el plan, ajustar las acciones, actualizar los controles y responder a nuevos riesgos. Cada vez que cambien los procesos, las herramientas, las finalidades o las bases de datos, el plan debe actualizarse para mantener su pertinencia y fortalecer de manera permanente la protección de la información personal.

Síntesis

A continuación, se presenta una síntesis de la temática estudiada en el componente formativo.



Glosario

Autorización: consentimiento otorgado por el titular para realizar el tratamiento de sus datos personales de acuerdo con las finalidades informadas.

Base de datos: conjunto organizado de datos personales que son objeto de tratamiento por parte de una organización.

Confidencialidad: principio orientado a evitar el acceso, uso o divulgación de información personal por parte de personas no autorizadas.

Control de acceso: medida que permite limitar el ingreso a sistemas, archivos, bases de datos o espacios de acuerdo con las funciones y responsabilidades asignadas.

Datos personales: información asociada o que puede asociarse a una persona natural determinada o determinable.

Datos sensibles: información cuyo uso indebido puede afectar la intimidad del titular o generar situaciones de discriminación.

Incidente de seguridad: situación que puede comprometer la confidencialidad, integridad o disponibilidad de los datos personales tratados por una organización.

Plan de mejora: conjunto organizado de acciones destinadas a corregir hallazgos, reducir riesgos y fortalecer las medidas para la protección de datos personales.

Riesgo: posibilidad de que ocurra una situación que afecte la protección de los datos personales, los derechos de los titulares o el cumplimiento organizacional.

Titular: persona natural cuyos datos personales son objeto de tratamiento.

Referencias bibliográficas

INCIBE. (2024, 17 de abril). Cifrado de la información. Instituto Nacional de Ciberseguridad. <https://www.incibe.es/ciudadania/tematicas/cifrado>

Kriptos. (2025, 2 de julio). Datos personales: qué es, tipos y ejemplos. Intelligent Solutions. <https://www.kriptos.io/es/es-post/datos-personales-que-es-tipos-y-ejemplos>

VIU. (2024, 22 de noviembre). Incidentes de seguridad: ¿cómo prevenirlos? Universidad Nacional de Valencia. <https://www.universidadviu.com/co/actualidad/nuestros-expertos/incidentes-de-seguridad-como-prevenirlos>

Créditos

Nombre	Cargo	Centro de Formación y Regional
Claudia Johanna Gómez Pérez	Profesional 06. Responsable Ecosistema Virtual de Recursos Educativos Digitales	Centro Agroturístico - Regional Santander
Joinner Enrique Osorio Martinez	Experto temático	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Paola Alexandra Moya	Evaluada instruccional	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Carlos Julian Ramirez Benitez	Diseñador de contenidos digitales	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Robinson Javier Ordoñez Barreiro	Desarrollador full stack	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Alejandro Delgado Acosta	Intérprete lenguaje de señas	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Cristhian Giovanni Gordillo Segura	Intérprete Lenguaje de señas	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Juan Pablo Rojas Polania	Animador y productor multimedia	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Carlos Eduardo Garavito Parada	Animador y productor multimedia	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Maria Carolina Tamayo Lopez	Locución	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
German Acosta Ramos	Locución	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Aixa Natalia Sendoya Fernández	Validador de recursos educativos digitales	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila

Nombre	Cargo	Centro de Formación y Regional
Ricardo Oliveros Zambrano	Validador de recursos educativos digitales	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Anyerson Wilfredo Pizo Ossa	Evaluador para contenidos inclusivos y accesibles	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila
Daniel Ricardo Mutis Gómez	Evaluador para contenidos inclusivos y accesibles	Centro Agroempresarial y Desarrollo Pecuario - Regional Huila